

TOM DENEYER

ANASTASIYA KOZLENKO

Cybersécurité BAC2
2024-2025

Email : tomdeney@gmail.com
Discord : Littl3T

HAUTE ECOLE EN HAINEUT

Table des matières

Introduction	3
UTM Fortigate (FortiOS7.4).....	3
Introduction.....	3
VDOM.....	3
Administration	4
Administrateurs	4
Protocoles Fortigate destinataire	4
Fonctionnalités masquées.....	4
Configuration d'interface.....	4
Autres configurations.....	5
Règles de Pare-Feu (Firewall Policies).....	5
Généralités	5
Types de journaux (logs).....	8
Modes d'inspection	9
NAT (Network Address Translation)	10
Généralités	10
Configuration.....	10
Routage.....	11
Généralités	11
Création d'une route statique	12
Policy-based routes	12
ECMP	13
RPF	14
VPN IPsec	15
Généralités	15
VPN Site à site.....	15
VPN d'accès (Dial up)	15
Avantages et Inconvénients	16
Terminologies	16
Chiffrement et Hash.....	16
Certificats	17
IPsec	18
Echange de clefs / DH.....	19
IKE phase 1	19
IKE phase2	19
Configurer un VPN IPsec Fortigate	20
Inspection SSL/SSH.....	20
Filtrage WEB.....	23
DNS filtering	25
Filtrage Video	25
Antivirus	26
Généralités	26
Modes d'inspections	26
Autres configurations et informations.....	27

Introduction

CCB (Center for Cybersecurity Belgium) – Autorité nationale en charge de la cybersécurité en Belgique.

- Identifier: Connaître les menaces cyber et gérer les risques relatifs aux actifs essentiels.
- Protéger: Mettre en place des mesures de protection pour atténuer les risques.
- Détecter: Assurer une détection rapide des événements de cybersécurité.
- Répondre: Mettre en place des contrôles pour réagir aux incidents de cybersécurité et en limiter l'impact.
- Récupérer: Mettre en œuvre des mesures pour restaurer les services après un incident cyber.
- Gouvernance(NIST 2.0) : Importance de l'aspect décisionnel de la cybersécurité.

Les **vulnérabilités** sont référencées et classées par le **MITRE (CVE)**.

Recherches des vulnérabilités :

- Analyser et tester le code source des programmes
- Utiliser des outils d'analyse (scanner) – doit être installé sur le matériel (performances ?)
- Scan manuel (pour vérifier une faille trouvée par les scanner pour le faux positif)
- Scan DB pour les injections SQL

UTM Fortigate (FortiOS7.4)

Introduction

Fortinet est une multinationale américaine depuis début 2000. Commercialise des équipements, logiciels, services de cybersécurité. Certification liée : **NSE** (Network Security Expert).

Les Firewall deviennent multifonctionnels depuis des années ; **NGFW** (Next generation Firewall) et peuvent servir à **segmentation** interne, **data center**, **distribué**... Et peuvent s'échanger des informations de sécurité entre eux via le **Fortinet Security Fabric**.

Les fortigates sont dispo en deux formes

- ❖ **Hardware** : Dimensionnés pour un nombre d'utilisateurs précis, possèdent des Security Processing Units (SPU) tel que Content, Security, Network et System-on-a-Chip-Processor
- ❖ **Virtuel (VM)** : Déploiement, démontage, et adaptation plus rapide, déployable sur VMWare, Hyper-V, KVM, AWS, Azure... Possèdent les mêmes fonctionnalités que les hardwares mais sans accélération matérielle.

Connexions possibles au Fortigate via CLI (Rj45, Usb, SSH, Telnet) ou GUI, FortiExplorer (IOS/Android)

Par défaut, IP sur tous les ports physique = 192.168.1.99/24 avec ssh, https et ping activés. Après un factory reset, credentials = 'admin, « »'

VDOM

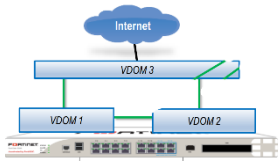
Les « virtual domain » sont une virtualisation dans le FortiOS qui le divise en plusieurs pare-feu virtuels sur un seul équipement physique. Pour visualiser l'ensemble des VDOM en configuration il faut un compte super administrateur.

Chaque VDOM a :

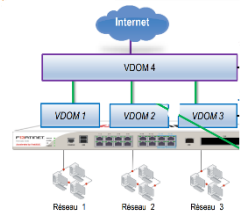
- ❖ Ses propres politiques de sécurité et règles de Fw
- ❖ Ses propres tables de routages...

- ❖ Un compte administrateur différent pour sa gestion mais qui n'a pas accès aux autres VDOM
- ❖ Ses propres interfaces physiques attribués

Il est possible de faire un VDOM supérieur qui par exemple analyse l'ensemble du Traffic de tous les VDOM. Et ensuite utiliser un Inter-VDOM link entre Vdom secondaire et le VDOM primaire.



Il est possible aussi avec des Vdom link de faire une topologie maillée entre tous les VDOM pour optimiser le flux du trafic, sans devoir passer par un VDOM commun.



Administration

Administrateurs

Les administrateurs peuvent être de différents types :

- ❖ **Local** (compte sur la machine)
- ❖ **Remote** (Active Directory ou LDAP)
- ❖ **PKI** (Certificat numérique)

Et il existe plusieurs profils administrateur différents associable à un compte administrateur :

- ❖ **Super_Admin** : Possèdent tous les droits, profil non modifiable
- ❖ **Prof_Admin** : Possèdent tous les droits, mais uniquement dans son VDOM, modifiable
- ❖ **Custom** : Autant de profils souhaités, avec les permissions spécifiques que l'on veut en R0 ou RW

Pour augmenter la sécurité, il est possible de donner un accès plus restreint aux comptes administrateur via :

- ❖ **Facteur à deux authentifications** pour la connexion via un FortiToken qui génère à code à l'utilisateur
- ❖ **Trusted host** : Ip ou sous-réseaux à partir du quel les administrateurs peuvent se connecter, pratique si VLAN de gestion par exemple.
- ❖ Modifier les **PasswordPolicies** et augmenter la complexité minimum des mots de passes

Protocoles Fortigate destinataire

- ❖ **Security Fabric Connection** avec Fortitelemetry : Utilisé pour la gestion des FortiClients, et CAPWAP pour la gestion de FortiAP, FortiSwitch, FortiExtender...
- ❖ **FMG-Access** utilisé pour communiquer avec les équipements FortiManager
- ❖ **RADIUS accounting** utilisé quand le fw a besoin de traiter des paquets RADIUS pour le SSO
- ❖ **FTM** utilisé pour l'application Mobile Fortitoken

Fonctionnalités masquées

Certaines fonctionnalités ne sont pas visibles en CLI il faut aller dans system>Features visibility pour les activer.

Configuration d'interface

Les « interface role » sont à paramétrer sur les interfaces pour n'afficher que les paramètres utiles à configurer, il en existe plusieurs types :

- ❖ LAN
- ❖ WAN
- ❖ DMZ
- ❖ Undefined : Donne accès à tous les paramètres

Il est possible de donner des « **Alias** » aux interfaces pour une administration simplifiée. Ainsi qu'ajouter un client **DHCP** sur l'interface.

Il est aussi possible de faire de l'**etherchannel** sur les interfaces (LACP) avec 4 interfaces physiques maximum.

Il existe deux types d'interfaces ; **physique** et **logique**, une interface physique peut être divisée en plusieurs interface logiques, comme les interfaces vlan. Interface identifiée à l'arrivée du trafic via le tag VLAN.

Autres configurations

- ❖ Il est souvent nécessaire de configurer une **route par défaut** pour communiquer avec des réseaux distants, vers sa passerelle par défaut.
- ❖ Une serveur **DHCP** en mode NAT peut être configuré sur les interfaces, avec toutes les options de base. En plus il est aussi possible d'assigner des règles spécifiques pour par exemple mapper une adresse **MAC** fixe à une Ipv4, ou bien bloquer des MAC.
- ❖ Pour sauvegarder la configuration il faut faire un backup, qui est restaurable par la suite.
- ❖ Pour les **updates de firmware**/version il faut utiliser le « Upgrade Path Tool Table » qui, avec un modèle et une version actuelle choisie, donne toutes les versions par lesquelles passer pour atteindre la version souhaitée. ATTENTION lire la release notes. Et toujours garder la version originale pour revenir à la version antérieure si jamais il y a des problèmes.
- ❖ **Fortiguard Subscription Service (FSS)** donne accès aux mises à jour des éléments de l'UTM(FW,AV,IPS), monitorer les licences... Le **FDN (Fortiguard Distribution Network)** est un réseau mondial de serveur qui distribue des mises à jour aux appareils Fortinet.



Il existe deux modes de fonctionnements du pare-feu :

- ❖ **Transparent mode (Bridge mode)** où le Fortigate fait office de commutateur de couche 2 donc toutes ses interfaces une seule IP dans le même réseau et donc certaines fonctionnalités ne sont pas disponibles. (Attention aux boucles de couche 2)
- ❖ **NAT/route mode** où le Fortigate travaille sur la couche 3 OSI, donc chaque interface est séparée, utilisé généralement quand le pare-feu est situé entre le réseau privé et publique.

Règles de Pare-Feu (Firewall Policies)

Généralités

Une règle de pare-feu (Unified Threat Management (UTM)) définit quel trafic est concerné et quelle action appliquer.

- Le nom d'une règle ne peut pas dépasser 35 caractères.
- Les lettres(de A à Z, Majuscule ou minuscule).
- Les nombres(de 0 à 9). – Les caractères spéciaux: “-” et “_”

Ordre des règles important : la 1ère correspondance s'applique (pas de test des suivantes).

Il existe une règle par défaut **Policy0** → action deny all - non supprimable, seule option modifiable : la journalisation (log).

Tous ces éléments doivent **correspondre simultanément** pour qu'une règle s'applique :

- **Interface** source et destination (From → To)
- **Adresses IP** source et destination
- **Horaire (Schedule)** : quand la règle est active

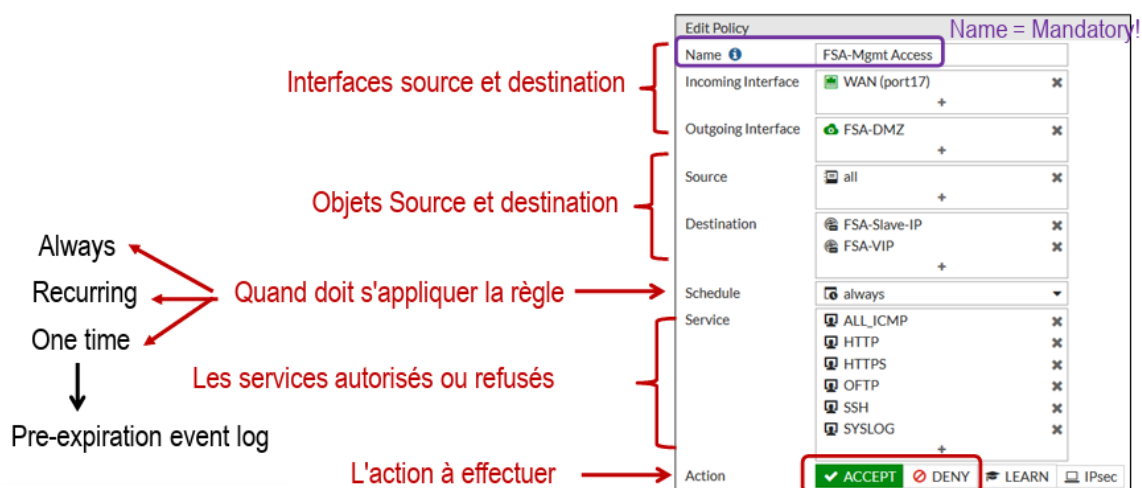
- **Service** : protocole + port (ex : HTTP, TCP/443)
- Si ok, FW vérifie les **profils de sécurité** (antivirus, filtres web, etc.)
- Si les profils de sécurité laissent passer le trafic, l'UTM vérifie si d'autres traitements doivent être appliqués : Authentification, NAT, journalisation, QoS, ...

Objets : interface, zone, adresse, utilisateur, service, profils de sécurité...

Suppression d'objet : on ne peut pas supprimer un objet qui est utilisé dans une règle. Il faut d'abord modifier la règle utilisant l'objet à supprimer.

La colonne ID : numéro unique de la règle (toujours utilisé en CLI), **Numéro de séquence** : ordre d'application (chaque quand on glisse la règle).

Une **zone** est un regroupement d'interfaces (physiques et/ou virtuelles).



La **source** (et la **destination**) **DOIT** être définie par un des éléments suivants :

- Une adresse ou un ensemble d'adresses IP.
- Un réseau ou sous-réseau.
- Une zone géographique.
- Un FQDN (doit pouvoir résoudre).
- L'adresse d'un Fabric connector (adresse dynamique) . Par ex une adresse dynamique provenant d'AWS (ex. : instances taguées env=dev)
- Un objet de la base de données "Internet service" (ISDB).

La source **PEUT**, en plus d'un objet adresse, être définie par :

- Un utilisateur ou un groupe d'utilisateurs source :
 - Un compte local.
 - Un compte sur un serveur distant (Active Directory, LDAP, RADIUS).
 - FSSO (FortinetSingle Sign-On).
 - Un utilisateur PKI (certificate).
- Un périphérique source -Peut être défini manuellement sur l'UTM ou via le service "Device Identification".

Internet Service Data Base (ISDB) - base de données qui contient une liste d'adresse IP, de protocoles et de numéros de port utilisés par les services Internet les plus courants. **Geographic Based Internet Service** – offre un contrôle plus précis en permettant de définir des objets ISDB sur base d'un pays, d'une région ou d'une ville.

- Si Internet Service est utilisé dans le champ source d'une règle, il n'est pas possible d'utiliser un autre objet adresse dans ce même champ source.
- Si Internet Service est utilisé dans le champ destination d'une règle:

Il n'est pas possible d'utiliser un autre objet adresse dans ce même champ destination.

Il n'est pas possible de sélectionner le champ «Service» de la règle.

Policy & Objects > Internet Service Database

+ Create New Edit

Geographic Based Internet Service

New Internet Service

Name	Training-location-ISDB	Master Internet Service Name	Google-Other
Type	Predefined Geographic Based	Master Internet Service ID	65536
Master Internet Service	Google-Other	Direction	
Country/Region	United Kingdom	Destination	
Region	England	Entries	
City	London	View/Edit Entries	

WALLONIE-BRUXELLES
ENSEIGNEMENT

pile manager

View Search

By Category Alphabetical

Service Name	Category	Details	IP/FQDN	show in Service List	Rel.
General (5)					
ALL	General	ANY		✓	0
ALL_ICMP	General	ICMP/ANY		✓	0
Web Access (2)					
HTTP	Web Access	TCP/80	0.0.0.0	✓	1
HTTPS	Web Access	TCP/443	0.0.0.0	✓	2
File Access (6)					

Exemples d'objets « Service » prédéfinis

Les **Profils de sécurité** - un groupe d'options et de filtres que l'on peut appliquer à une règle de pare-feu.

Si le trafic est autorisé par la règle de pare-feu, alors on peut l'inspecter plus en profondeur via les profils de sécurité

Security Profiles

AntiVirus	AV	default	
Web Filter	WEB	default	
Video Filter	VF	video_filter	
DNS Filter	DNS	default	
Application Control	APP	default	
IPS	IPS	default	
File Filter	FILE	default	
Email Filter	EMAIL	default	
DLP Profile	DLP	default	
SSL Inspection	SSL	deep-inspection	

Decrypted Traffic Mirror

Policy Look up ou Policy match – Permet de rechercher si une règle correspond à un type de trafic

Policy match

Policy	Source	Destination	Schedule	Service	Action	IP Pool	NAT	Status
port3 → port1	all	all	always	ALL	ACCEPT			Stable
Internet (2)	all	all	always	ALL	ACCEPT		NAT	Stable

Mise en surbrillance de la correspondance trouvée

Seq.#	Name	Source	Destination	Schedule	Service	Action	NAT
port3 - port1 (1 - 3)							
1	Test1	10-0-1-subnet	all	always	FTP	Accept	Enabled
2	Test2	10-0-1-10	Fortinet_FQDN	always	ALL	Accept	Enabled
3	Full_Access	all	all	always	ALL	Accept	Enabled

Types de journaux (logs)

1. Traffic logs

- Journaux de sessions réseau (source, destination, port, action...)
- Affichent quelles règles de pare-feu ont été utilisées
- Active uniquement sur les règles configurées avec l'option "Log"
- Par défaut, ils sont visibles dans le menu ForwardTraffic

#	Date/Time	Source	Destination	Application Name	Security Events	Result	Log Details
1	00:06:59	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	General Date: 02/12/2018 Time: 23:51:29 Duration: 0s Session ID: 69656 Virtual Domain: root Source IP: 10.0.0.2 Source Port: 138 Country: Reserved Source Interface: port1 Security Level: Threat Level: high Threat Score: 30 Notice
2	00:06:29	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
3	02-12 23:54	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
4	02-12 23:51	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
5	02-12 23:42	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
6	02-12 23:36	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
7	02-12 23:30	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
8	02-12 23:21	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
9	02-12 23:18	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
10	02-12 23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	
11	02-12 23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violation	

2. Event logs

- Enregistre les changements d'état, connexions d'administration, erreurs système, etc.

3. Security logs

- Journaux liés aux modules de sécurité
- Certains activent la journalisation automatiquement (ex : antivirus, IPS...)
- Par défaut, ils sont visibles dans le menu ForwardTraffic

Dashboard

FortiView

Network

System

Policy & Objects

Security Profiles

VPN

User & Device

WiFi & Switch Controller

Log & Report

Forward Traffic

Local Traffic

System Events

WiFi Events

AntiVirus

Date/Time: >> 06/28/2016 05:15:21

Add Filter

Log location: Disk

Details

Date/Time	Source	Destination	Security Events	Log Details
06-28 07:10	10.0.1.10	52.203.0.102 (server-52-203-0-102.us-west-2.compute.amazonaws.com)		
06-28 07:17	10.0.1.10	52.32.150.180 (ec2-52-32-150-180.us-west-2.compute.amazonaws.com)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.252 (secure.eicar.org)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info) [P]	1	
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.252 (secure.eicar.org)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:17	10.0.1.10	188.40.238.250 (fppsi.itcon.info)		
06-28 07:16	10.0.1.10	52.85.63.60 (server-52-85-63-60.lhr50.r.cloudfront.net)		
06-28 07:16	10.0.1.10	72.21.91.29 (ocsp.digicert.com)		

Details

Security

AntiVirus

Agent: Firefox/47.0

FortiSandbox Checksum: 275a021bbf6489e54d

Submitted to FortiSandbox: false

Details: host: 188.40.238.250

Threat Level: critical

Direction: incoming

Detection Type: Virus

Event Type: infected

File Name: eicar.com.txt

Message: File is infected.

Profile Name: anotherAV

Quarantine Skip: File was not quarantined

Reference: http://www.fortinet.com

URL: http://www.eicar.org/idos

Virus/Botnet: EICAR_TEST_FILE

Virus ID: 2172

4. System logs

- Informations sur le matériel, les services, les mises à jour, crashes, etc.

Où activer la journalisation ? Dans chaque **policy de pare-feu** → Option "**Log Allowed Traffic**" :

- All Sessions
- Security Events
- Disable

Il est possible de spécifier quel sous-type de trafic devra être journalisé concernant les types de journaux «**Event**» et «**Local Traffic**»

Log & Report > Log Settings

Trafic « de » et « vers » le FortiGate

Pour RGPD parfois il faut anonymiser les utilisateurs

```
# config log setting
  set user-anonymize enable
end
```

```
# execute log display
Date=2021-02-04 time=10:06:10 logid=0215013713 type=utm
subtype=webfilter eventtype=ftgd_allow level=notice vd="root"
policyid=2 identidx=1 sessionid=42342848 user="anonymous"
group="ldap_users" srcip=192.168.0.2 srcport=62423
srcintf="port3" dstip=193.190.65.24 dstport=80 dstintf="port1"
service="http" hostname="www.heh.be"
profiletype="Webfilter_Profile" profile="default"
status="passthrough" reqtype="direct" url="/" sentbyte=304
rcvbyte=60135 msg="URL belongs to an allowed category in
policy" method=domain class=0 cat=140 catdesc="custom1"
```

Modes d'inspection

Flow-based vs Proxy-based - ce sont deux modes d'analyse du trafic utilisés par les moteurs de sécurité du pare-feu pour détecter les menaces ou appliquer des filtres (antivirus, web filtering, etc.).

Flow-based (inspection par flux)

- Le pare-feu inspecte les paquets en temps réel, au fur et à mesure qu'ils passent.
- Il ne conserve qu'une copie partielle du flux.
- L'analyse est faite à la volée par moteur rapide.

Avantages

- Très rapide et performant
- Moins de consommation mémoire/CPU
- Idéal pour trafic volumineux ou latence faible, quand le choix est débit > sécurité

Inconvénients

- Moins d'analyse en profondeur (DPI)
- Moins précis sur certains contenus complexes (ex : protocoles encodés, gros fichiers compressés)

Proxy-based (inspection par proxy) - Le pare-feu agit comme un proxy intermédiaire :

- Il intercepte, stocke et analyse entièrement les contenus dans sa mémoire tampon
- Puis il transmet ou bloque selon la politique

Avantages

- Analyse plus profonde (deep inspection)

Inconvénients

- Consomme plus de ressources (RAM, CPU)

- Peut modifier activement les requêtes/réponses (ex : retirer une pièce jointe)
- Supporte le filtrage Vidéo, les options du filtrage web (par exemple: les quotas d'utilisation, le «safe search» ou encore l'option «web-profile override» du profil de filtrage Web), le Web Application Firewall, ...
- Meilleur contrôle sur HTTP, HTTPS, FTP...
- Plus de latence (traitement plus lent)

NAT (Network Address Translation)

Généralités

Types de NAT :

- ❖ **SNAT** (Source NAT), fonction NAT/PAT qui « traduit » l'IP source
- ❖ **DNAT** (Destination NAT), fonction NAT/PAT qui « traduit » l'ip destination
- ❖ **PAT** (Port Address Translation) qui modifie l'adresse source et le port source d'un paquet, NAT overload
- ❖ **NAT64**, **NAT46**, fonction qui « traduit » Ipv4 ⇌ Ipv6
- ❖ **NAPT** (Network Address & Port Translation), acronyme qui désigne à la fois du NAT avec PAT

Avantages NAT

- ❖ Assure une cohérence des schémas d'adressage interne
- ❖ Economie adresse publique
- ❖ Sécurité et confidentialité

Inconvénients NAT

- ❖ Dégradation des performances surtout pour les applications temps réels
- ❖ Certaines applications non compatibles
- ❖ Perte de traçabilité d'IP de bout en bout

Configuration

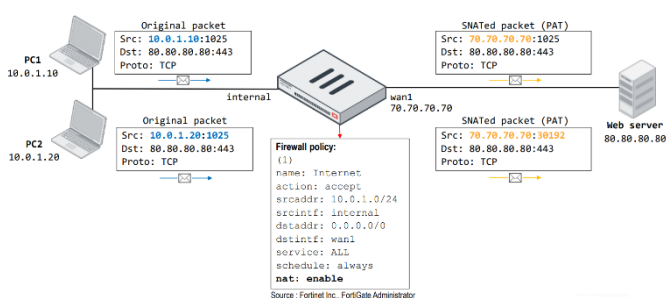
Deux méthodes :

- ❖ **Firewall Policy NAT mode** :
SNAT et DNAT configuré sur chaque règle appliquée, le SNAT utilise l'IP de l'interface de sortie ou pool configuré. Et DNAT utilise l'IP virtuelle (VIP) configurée comme adresse de destination.
- ❖ **Central NAT mode** :
Permet la création de plusieurs NAT centralisées, les règles sont lues séquentiellement et c'est configurable par VDOM. Permet une meilleure précision (par exemple choisir les ports manuellement).

Pour la configuration **SNAT policy based**, il faut sélectionner l'option NAT, et l'ip source du paquet traité sera remplacée par l'IP de l'interface de sortie, par défaut le PAT est activé, mais on peut désactiver la traduction de port en conservant le port source.

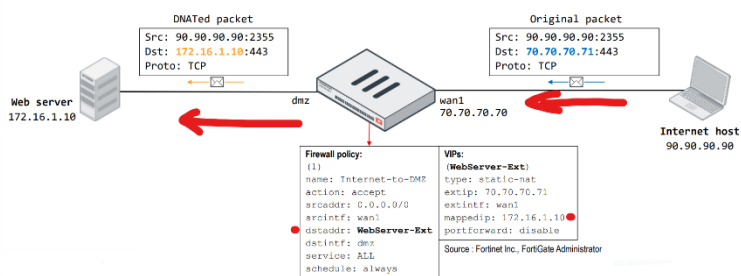
Exemple ici à droite ➔

Plusieurs types de pool ip pour SNAT :



- ❖ **Ip Pool Overload**, il modifie l'adresse avec les ip du pool à la place de l'ip de l'interface de sortie, et par défaut utilise du PAT
- ❖ **Ip Pool One-to-One**, égal à du NAT dynamique, utilise la premier ip disponible du pool, premier arrivé, premier servi, PAT désactivé.

Les VIP (Virtual IP) sont des objet FortiGate utilisé pour le **DNAT**, permet de lier une adresse IP externe à une interne. Souvent utilisé pour rediriger un trafic entrant vers un serveur interne. Les VIP sont du NAT statique par défaut. Et ces VIP doivent être routables vers l'interface externe, avec une possibilité de faire du load balancing si plusieurs serveurs interne accessible depuis la même ip externe.



Port forwarding utilisé pour rediriger le trafic de ports d'une VIP sur certains ports internes. Souvent utilisé pour rediriger le trafic web vers le serveur web d'une DMZ par exemple.

L'activation d'une VIP ou pool IP active l'**ARP reply**, ce qui a pour conséquence que le FortiGate va répondre aux requêtes ARP entrantes avec l'adresse externe configurée dans les VIP/Pools.

Routing

Généralités

RIB Routing Information Base

Table de routage standard contenant les routes actives (meilleures routes) reçues via :

- Protocoles de routage (BGP, OSPF, etc.)
- Routes statiques
- Routes connectées

FIB Forwarding Information Base

- Table de routage vue du point de vue du noyau
- Composée principalement des entrées de la RIB et d'entrées spécifiques au système.
- Utilisée pour la recherche de routes (et donc pas la RIB).
- Visible uniquement en CLI

En résumé, La **RIB est logique**, la **FIB est réelle** et utilisée pour l'acheminement.

Les routes peuvent être configurées **manuellement ou dynamiquement**

- Plusieurs protocoles de routage dynamique sont supportés–RIP, OSPF, IS-IS et BGP.
- System > Feature Visibility> Advanced Routing

Directly connected	0
DHCP gateway	5
Static routes	10
EBGP routes	20
OSPF routes	110
RIP routes	120
IBGP routes	200

Figure 1. Distance administrative des routes

Création d'une route statique

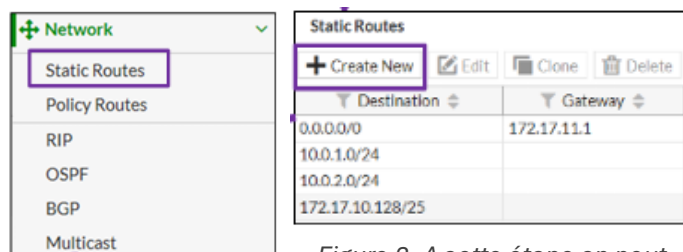


Figure 2. A cette étape on peut choisir ipv6 ou ipv4

En activant l'option "**Static Route Configuration**" dans un objet adresse, on peut l'utiliser comme destination dans une route statique au lieu de taper le subnet.

Étapes de sélection d'une route (ordre de priorité)

1. **Correspondance du préfixe la plus spécifique** (ex : /24 est plus spécifique que /16).
2. **Distance administrative (Administrative Distance – AD)**

Si plusieurs routes ont le même préfixe, la route avec l'AD la plus basse est choisie.

3. Priorité (FortiGate spécifique)

Si plusieurs routes statiques ont le même masque ET la même AD, alors FortiGate utilise la priorité pour choisir la meilleure. La valeur la plus faible l'emporte

4. ECMP (Equal Cost Multi-Path)

Si plusieurs routes ont le même préfixe, la même AD, même priorité, et sont toutes valides, FortiGate peut :

- soit faire du load balancing entre elles (si ECMP est activé),
- soit utiliser la première route dans la table (si ECMP est désactivé).

Policy-based routes

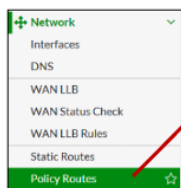
La **Policy-Based Route (PBR)** permet de forcer un trafic spécifique à emprunter une route donnée, en se basant sur des critères autres que la destination IP.

- Les Policy-based routes utilisées avec l'action **Forward Traffic** ont priorité sur les routes statiques et dynamiques.
- Ainsi, si un paquet correspond à une Policy-based route, la table de routage (R.T.) n'est pas utilisée.
- Elles sont maintenues dans la **Policy Routing Table**, séparée de la R.T. Il doit cependant exister une route active (route + interface de sortie) vers la destination.
- Les règles sont lues dans l'ordre.
- Une nouvelle règle est placée à la fin de la liste.

Contrairement au routage classique (basé uniquement sur la destination IP), le PBR prend en compte :

- L'interface d'entrée
- L'IP source
- Le port source ou destination
- Le protocole
- L'utilisateur (avec authentification) etc

Policy routes



En plus des interfaces src/dst et IP src/dst, les critères suivants sont utilisables :

New Routing Policy

If incoming traffic matches:

Protocol: TCP UDP SCTP **ANY** Specify 0

Incoming Interface: +

Source address / mask: Examples: 10.80.0.1/24, 192.168.1.2/24

Destination address / mask: Examples: 10.80.0.1/24, 192.168.1.2/24

Type of Service: Bit Pattern 0x00 Bit Mask 0x00

Pour ne pas utiliser un paramètre, il faut laisser le champ vide.

Si correspondance, deux actions sont possibles :

1) **Forward Traffic** : Acheminer le paquet vers l'interface de sortie et la passerelle configurées.

Then:

Action: **Forward Traffic** Stop Policy Routing

Outgoing Interface: [dropdown]

Gateway Address: 0.0.0.0

Comments: [text area]

Status: **Enabled** Disabled

2) **Stop Policy Routing** : utiliser la table de routage

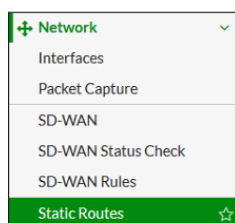
Then:

Action: Forward Traffic **Stop Policy Routing**

Comments: [text area]

Status: **Enabled** Disabled

Route statique utilisant Internet Services



Edit Static Route

Destination: Subnet Named Address **Internet Service**

Device: Microsoft-Skype

Device: port1

Gateway: 172.30.72.254

Comments: [text area]

Status: **Enabled** Disabled

Utilisé comme destination dans une route statique

- Ces routes ne sont pas ajoutées à la table de routage mais à la policy routing table.
- Bien que l'on configure une route statique (Network > Static Routes).

ECMP

L'**ECMP** (Equal Cost Multi-Path) permet à FortiGate d'utiliser plusieurs routes ayant exactement le même coût (même masque, même distance administrative, et même priorité) pour répartir le trafic sur plusieurs chemins. FortiGate active automatiquement l'ECMP si les routes sont équivalentes.

Le **paramètre de priorité** est spécifique à Fortinet : il permet de gérer les cas de routes statiques similaires mais non totalement équivalentes.

Avantages :

- Utile pour les services critiques qui nécessitent une haute disponibilité.
- Améliorer la bande passante en répartissant la charge des sessions sur plusieurs interfaces.

ECMP entre ces deux routes

```
FGT # get router info routing-table all
s 10.0.4.0/24 [10/0] via 10.0.3.254, port1, [5/0]
   [10/0] via 10.200.3.254, port2, [5/0]
   [10/0] via 10.200.3.254, port2, [10/0]
```

[Distance administrative / métrique]

[Priorité / poids]

Méthodes de balancement de charge ECMP

Quand FortiGate utilise ECMP, il doit décider comment répartir les sessions entre ces routes.

1. Source IP (par défaut)

- Chaque session provenant d'une adresse IP source unique emprunte toujours la même route ECMP.
- Permet de garder la cohérence des flux, utile pour NAT ou certains protocoles sensibles.

2. Source-destination IP

- La sélection se fait selon le couple IP source + IP destination.
- Plus précis que le mode précédent → une même IP source peut emprunter plusieurs chemins si elle communique avec plusieurs destinations.

Exemple pour les deux :

Disons qu'on a 2 routes ECMP (WAN1, WAN2) :

- FortiGate reçoit une session : 192.168.1.10 → 8.8.8.8
- Il applique $\text{hash}("192.168.1.10+8.8.8.8") = 11784$
- $11784 \% 2$ (quantité de routes) = 0 → donc Route ECMP n°0 → WAN1

Une autre session :

- 192.168.1.10 → 1.1.1.1
Hash = 12361
 $12361 \% 2 = 1 \rightarrow \text{WAN2}$

3. Weighted (pondéré)

- S'applique uniquement aux routes statiques.
- Chaque route ECMP est associée à un poids (priorité).
- Le trafic est réparti en fonction du rapport entre les poids.

Exemple :

- Route A → poids 5
 - Route B → poids 3
- > FortiGate répartit le trafic en 5/8 sur A et 3/8 sur B (total = 5 + 3 = 8 parts).

4. Usage (Spillover)

- Utilise une seule route (la première) jusqu'à ce que sa bande passante soit saturée.
- Ensuite, FortiGate redirige l'excès de trafic (débordement) vers une autre route.
- Idéal pour prioriser une ligne principale mais basculer automatiquement en cas de saturation.

RPF

Reverse Path Forwarding (RPF) est une vérification de sécurité réseau qui consiste à s'assurer que le chemin retour d'un paquet IP est cohérent avec la route de départ.

Protège contre :

- Spoofing IP (usurpation d'adresse IP)
- Attaques DDoS avec adresses falsifiées
- Asymétrie de routage non désirée

Quand s'applique la vérification ?

- Sur le premier paquet d'une session
- Ou sur un paquet après un changement de routage

Modes :

1. Strict RPF

- Le paquet est accepté uniquement s'il arrive sur l'interface par laquelle la réponse serait envoyée ET si cette route est la meilleure route vers l'IP source.
- Très sûr, mais ne supporte pas bien les routes asymétriques (par ex. load balancing).

2. Loose RPF (Feasible path)

- Le paquet est accepté s'il existe une route de retour vers l'IP source, peu importe l'interface d'arrivée.
- Moins strict, mais plus tolérant pour les architectures complexes.

VPN IPsec

Généralités

Aujourd'hui, beaucoup d'accès sont nécessaires d'un peu partout pour les réseaux privés, donc plusieurs solutions sont possibles pour s'y connecter :

- ❖ Via réseau **WAN** direct : Sécurisé et fiable, mais cher pour chaque liaison donc impensable pour le télétravail.
- ❖ Réseau **public** : pas cher mais pas sécurisé, attaques et vulnérabilités possibles.
- ❖ Virtual Private Network (**VPN**) : pas cher et sécurisé, en passant par les réseaux publics gratuit.

Les VPN utilisent plusieurs technologies : **Tunneling**, **Authentication**, **Chiffrement**, échange de **clefs**... Ils permettent une connexion bout en bout entre deux réseaux privés ce qui permet la communication de ces réseaux de manière « locale »...

Le V de VPN c'est car la connexion n'est pas matérialisée par des connexions physiques dédiées à cette liaison.
Le P c'est car toutes les données sont chiffrées.

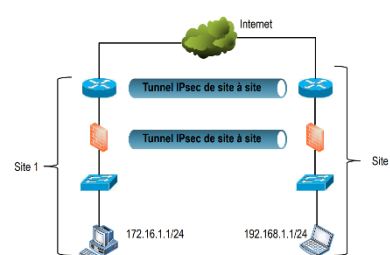
Intranet VPN	Extranet VPN
❖ Donne accès entre différents sites ou bureaux d'une même entreprise... ❖ Même politiques de sécurités partout	❖ Etendre la connexion de certaines ressources à des clients, fournisseurs, ... ❖ Les différents sites ne se voient généralement pas entre eux.

ATTENTION, les VPN ne chiffrent pas forcément les données, si chiffré alors on parle de VPN SSL / VPN Ipsec

VPN Site à site

Configuration de VPN utilisée pour connecter deux réseaux entiers ensemble, les hôtes n'ont pas connaissances du VPN.

La connexion se fait grâce à deux passerelles VPN situé sur chaque côté des réseaux connectés. Ces passerelles encapsule/désencapsule et chiffre/déchiffre le trafic passant d'un côté à l'autre. Ceux-ci peuvent être des routeurs/FW/ou autre chose avec une fonctionnalité VPN.

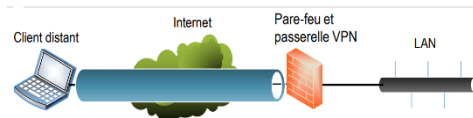


Ce type de VPN est statique = toujours actif

VPN d'accès (Dial up)

Configuration de VPN généralement utilisée pour connecter un télétravailleur à un intranet via une connexion haut débit.

Les VPN d'accès ne sont pas statiques, ils sont activés et désactivés à la demande de l'utilisateur, il demande généralement l'installation et configuration d'un client VPN sur PC. (Parfois non)



Architecture basée sur Client/serveur. Le firewall fait office de serveur par exemple, et la demande d'accès lui est envoyée par le client, ce qui engendre la création d'un tunnel VPN sécurisé entre eux.

Avantages et Inconvénients

Avantages	Inconvénients
❖ Sécurité du VPN qui inclue des protocoles de chiffrement, anti-rejeu... Sécurise les données à la couche réseau (pas application) ❖ Productivité et flexibilité pour les entreprises ❖ Réduction des coûts car pas besoins de liaison WAN dédiée pour les utilisateurs à distance. ❖ C'est Evolutif ❖ Compatible avec toutes les technologies haut débits... et souvent supporté nativement pour tous les équipements	❖ Niveaux de services pas garantis (repose sur la fiabilité du FAI) ❖ Source potentielle de lenteur car plus grosse charge processeur pour chiffrer/déchiffrer + distance physique du client ❖ Confidentialité propre au fournisseur de service VPN qui peuvent tracer les données...

Terminologies

- ❖ Chiffrement : Transformer un message clair en un code chiffré non lisible sans déchiffrement
- ❖ Cryptanalyse : Etude des procédés de déchiffrement
- ❖ Cryptographie : Etude du chiffrement
- ❖ Cryptologie : Science qui étudie le chiffrement des messages pour assurer la confidentialité, authenticité et/ou intégrité (cryptographie + cryptanalyse)
- ❖ Cryptosystème : Chiffrement basé sur des transformation mathématiques
- ❖ Attaque (en cryptologie) : Tentative de cryptanalyse.
- ❖ Casser (un code) : Mener à bien une attaque et déchiffrer un message chiffré

Chiffrement et Hash

Différentes techniques sont utilisées : Substitution, transformations et permutations, portes logique XOR, addition modulo-N, ...

Les algorithmes modernes dépendent de clefs de chiffrement et déchiffrement.

Le degré de sécurité dépend de l'algorithme + complexités des clefs, mais plus compliqué = plus long à chiffrer et déchiffrer même en connaissant les bonnes ressources.

(Le cours parle de chiffrement symétrique, asymétrique, RSA etc... Tout ça est vu est revu, voir les autres synthèses jpp)

HMAC(Hash Message Authentication Code) : à clef est un algo utilisé pour vérifier l'intégrité des données via un envoi des données et du hash et à la réception calcul du hash à partir des données reçues pour comparer les hash reçu et calculé ! Utilisé avec une clef de chiffrement.

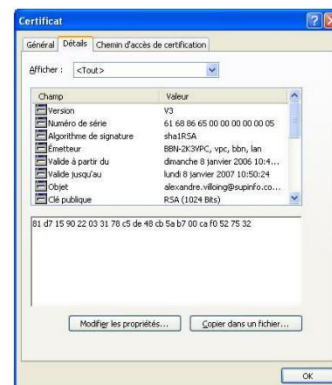
Les **signature Electronique** garantissent l'intégrité de la signature car utilisation de clefs asymétriques.

La **signature Numérique** utilise aussi une paire de clef asymétrique certifiée par un tier partie fiable. Les signatures numériques ont la même valeur qu'une signature manuscrite. Attention signé ≠ chiffré

Certificats

Un certificat est un **petit fichier** d'identité reliant les **clefs à une entité**. Les certificats fonctionnent quand ils sont émis par une autorité de certification (CA) qui certifie l'authenticité de la source. Ces certificats sont reconnus sur internet quand ils sont émis par des CA reconnus, s'ils sont autosigné alors pas de confiance globale. Voilà la structure d'un certificat de norme X509 :

Version – Numéro de série du certificat – Emetteur(DN) – début de validité – fin de validité – Objet (DN du détenteur de la clef publique/privé ?) – Clef publique – Contraintes de base- Utilisation de la clef – Algorithme de signature – Signature numérique du CA



Les certificats **auto-signés** sont à **utilisation interne**, mais gratuits et faciles à mettre en place, cependant sans ajouter le CA sur les clients internes le navigateur met des messages de non-fiabilité.

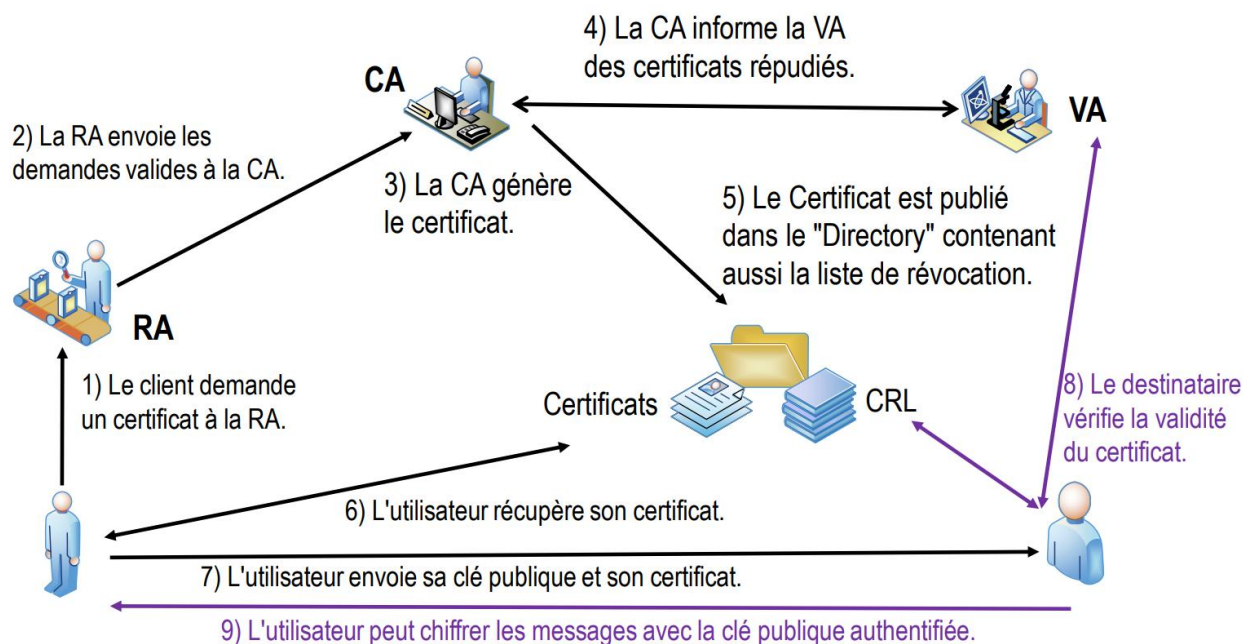
Différents types de certificats selon l'utilisation :

- ❖ Certificat de **signature** : Associer l'identité d'une personne à une clef publique, pour signer des messages électroniques, authentifier des sessions sécurisées...
- ❖ Certificat **serveur** : Associer l'identité d'un serveur à une clef publique, installé sur le serveur directement le plus courant actuellement c'est SSL. Utilisé pour les sites web par exemple.
- ❖ Certificat **VPN** : Associer un nœud du réseau à une clef publique pour garantir la sécurité entre les sites à travers des tunnels VPN.
- ❖ Certificat de **signature de code** : Signer un programme ou un script, logiciel... pour valider son authenticité et protéger contre le piratage.

Les certificats sont le plus souvent logiciels, mais ils existent aussi en format **matériel physique** en clef USB ou puce.... Généralement protégé par un code PIN ça permet de signer un document ou s'authentifier sur une application.

Les **autorités de certification (CA)** créent, valident et délivrent des certificats. Les certificats sont publiés dans « **The Directory** », et ils ont le pouvoir de révoquer un certificat en cas de compromission de clef à la demande du client. Ils utilisent des **opérateurs de certification** pour héberger les clefs et des Registration authority (**RA**) pour recueillir les demandes de certificats et le contrôle d'identité. Utilisent aussi des Validation Authority (**VA**) pour vérifier les validités ainsi que les TSA (Time Stamp Authority) pour vérifier l'horodatage des données)

Toutes ces structures différentes sont gérées par une **PKI (Public Key Infrastructure)** qui regroupe CA, RA, VA, les logiciels, et tout ce qui est utilisé pour le cycle de vie des certificats. Les PKI fonctionnent comme ceci :



Les Fortigate peuvent utiliser des certificats pour l'authentification, en vérifiant les champs du certificat comme la validité ou la révocation de celui-ci via numéro de série, et le Fortigate doit posséder le certificat du Issuer dans son magasin, vérification de la signature numérique et le reste.

IPsec

Internet Protocol Security est un standard ouvert (RFC2401) qui encapsule et protège les flux au niveau couche réseau. Souvent associé aux VPN. IPsec est indépendant des algorithmes de sécurités, il vérifie les communications avec des mécanismes à suivre : **authentification, intégrité, échange de clefs, chiffrement**, etc

Protège aussi contre le **rejeu**. Le rejeu qui consiste à capturer les paquets et de les renvoyer ce qui permet à l'attaquant de bénéficier des avantages de l'expéditeur. La protection fonctionne grâce à la vérification du numéro de séquence des paquets.

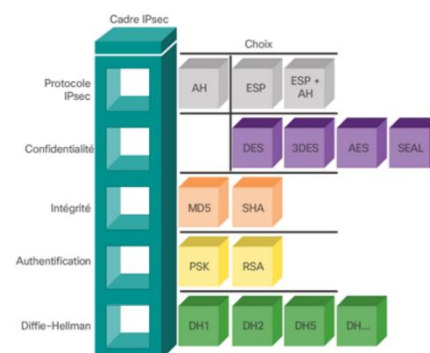
Même si les applications possèdent une sécurité applicative (SSL/TLS) important d'ajouter **Ipsec** pour **couche réseau**.

AH, ESP / AH+ESP sont deux services utilisés seuls ou associés

Le champ **AH (Authentication Header)** est inséré dans le paquet entre Data et HeaderIP, et utilisé pour vérifier l'authentification. Ça n'assure pas la confidentialité des données, c'est envoyé en clair. **Incompatible NAT/PAT**. Alors ESP encapsulé dans le AH.

ESP (Encapsulating Security Payload) assure la confidentialités, intégrité et unicité des données ! c'est aussi inséré (avant et après) sur le paquet IP. ESP chiffre les données utiles mais pas les en-tête IP. Incompatible PAT...

Le **NAT-T (NAT transversal)** permet aux paquets avec IPsec de traverser du NAT. Le NAT-T encapsule les paquets dans des segments UDP :4500 et donc les ip peuvent être modifiée par le NAT.



IPsec over UDP fonctionne comme le NAT-T mais il encapsule directement en UDP donc permet de configurer le port.

Mode d'échange IPsec :

- ❖ Transport : Utilise en-tête ip original, pour les communications « hôte à hôte » entre PC et serveur. Sécurisé mais ce n'est pas un tunnel vpn. N'encapsule pas tout le paquet.
- ❖ Tunnel : Encapsule le paquet IP entier, utilisé dans des communication réseau à réseau comme passerelles VPN ou hôte à réseau ou hôte à hôte. Convient dans la plupart des cas. Vu que c'est un tunnel pas besoin de NAT !

Echange de clefs / DH

Le Key-management (gestion de clef) permet la vérification du chiffrement de plusieurs clefs connues. Gérer manuellement toutes les clefs peut être très compliqué et fortement déconseillé...

IPsec utilise un protocole pour l'échange de clef comme IKE(v2) (Internet Key Exchange) qui permet aux deux extrémités de configurer automatiquement les clefs à utiliser. IKE utilise le port UDP :500 ou UDP :4500 si NAT.

Certains algorithmes (**Diffie-Hellman = DH**) permettent le partage de clef symétrique chiffré de manière sécurisée pour ne pas avoir à échanger des clefs publiques au préalable... Utilisé dans des normes comme IPsec et TLS.

DH utilise des groupes numérotés selon leurs force de sécurité (plus élevé = plus sécurisé mais plus lent). Cependant DH ne permet **pas la signature** des informations donc sensible à MITM, mais généralement associé à un algo de signature comme DSA/DSS

Les **Security Association (SA)** permettent de représenter les informations pour les échanges de flux de données aux deux extrémités des tunnels afin de gérer la sécurité unidirectionnelle entre deux périphériques. Ils ont une durée négociée par les deux bouts. ISAKMP(Internet Security Association Key Management Protocol) automatise la configuration des SA.

Les SA connues par un périphérique sont sauvegardées dans les SADB (Database) ou SAD, index = SPI (Security Parameters Index) attribué à chaque SA.

IKE phase 1

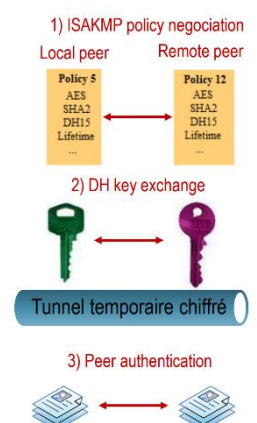
Objectif est de créer un tunnel sécurisé temporaire pour envoyer les infos pour la phase 2, comme la clef secrète.

1. Négociation ISAKMP policy (bidirectionnelle), les paramètres sont stockés dans une SA.
2. Echange d'une première clef en utilisant DH
3. Authentification des hôtes + hash payloads. Via une clef à configurer de chaque côté ou une signature digitale (certificat) recommandée.

Il en existe deux types (normal et agressif), en normal il est plus lent et envoyés en 6 messages et plus sécurisé. Tandis que le agressif c'est en 3 messages ce qui est plus rapides, à utiliser si plusieurs clients dial-up distants.

IKE phase2

Objectif est de négocier des paramètres SA IPsec pour établir le tunnel, avec une renégociation periodique des SA.



Il existe deux modes de IKE phase 2 :

Quick mode se base d'ancienne clef pour renégocier les nouvelles clefs secrètes.

Quick mode PFS (Perfect Forward Secrecy) dans lequel DH est utilisé à chaque fois pour recalculer une nouvelle clef secrète.

Configurer un VPN IPsec Fortigate

Les FortiGate proposent des Template de configuration pour simplifier la vie. Comme :

- ❖ « Dial-up Forticlient »: config entre un PC et le périphérique (besoin de FortiClient installé sur client)
- ❖ « Site to site – Fortigate»: VPN entre deux FortiGate
- ❖ « Site to site – Cisco »: VPN Entre Fortigate et firewall cisco
- ❖ «Custom»: creation de son propre template

Depuis FortiOS 5.2, assistant de configuration Wizard disponible où il ne suffit plus que de paramétrer les configurations de phases IKE.

Avec les configurations simplifiées, il suffit de définir port de sortie locale joignable par Client/Serveur et IP externe distant, Port local de sortie vers le réseau LAN, le subnet utilisé, etc...

Le tunnel VPN = interface virtuelle routable.

En configuration manuelle il y a plusieurs moyens :

- ❖ VPN mode route (interface based): Configuré manuellement avec un meilleur contrôle et plus flexible. C'est ce qui est utilisé par le wizard.
- ❖ VPN en règle (Policy based) : masqué par défaut en GLI. La règle est bidirectionnelle. Mais non routable ni considéré comme une interface...

Pendant la configuration manuelle, si utilisation du NAT-T, possibilité de modifier le DPD (Detection de tunnel défaillant ou mort via envoie de paquet DPD) Utilisation du NAT-T si au moins une des deux passerelles VPN est derrière un NAT, alors UTM encapsule en UDP :4500

Lors de la configuration de l'authentification via PreShared Key, possibilité d'ajouter **XAUTH** qui apporte une protection en plus via username/password en plus.

Les **Quick Mode Selector** sont des **filtres** pour le trafic IPsec, comme des règles de pare-feu.

Monitoring des tunnels via dashboard GLI ou commandes CLI, tout comme la journalisation des évènements VPN.

Inspection SSL/SSH

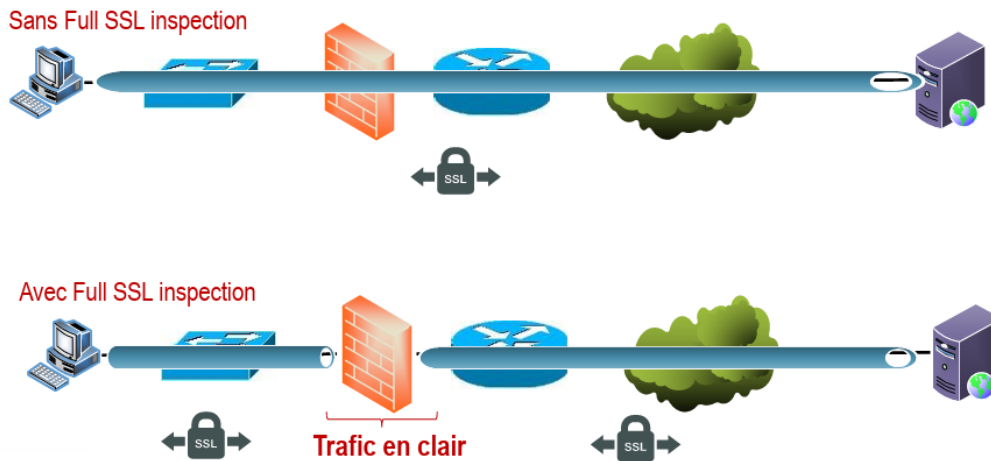
Trafic chiffré :

- Le contenu du trafic chiffré (SSL/TLS, SSH) n'est pas lisible par défaut, donc impossible de détecter virus, attaques, injections...
- Les pare-feux de nouvelle génération (NGFW) peuvent déchiffrer ce trafic pour appliquer des contrôles de sécurité (antivirus, IPS...).

Modes :

SSL Certificate Inspection • Vérifie uniquement les certificats SSL	Fonctionnement : • FortiGate vérifie uniquement la validité du certificat SSL du serveur distant.
--	--

• Rapide et peu consommateur de ressources • Peu sécurisée, ne permet pas d'inspecter le contenu	• Si le certificat est valide, la connexion est autorisée même si le contenu peut être malveillant. • L'URL ou nom de domaine (FQDN) est extrait via: - Le champ <i>SNI (Server Name Indication)</i> du handshake TLS - Ou les champs <i>Subject / Subject Alternative Name</i> du certificat Limites : • Les virus, malwares ou attaques dans le contenu ne peuvent pas être détectés • Seules les fonctions comme le filtrage web ou le contrôle d'application fonctionnent
Full SSL Inspection (Deep Inspection) • Déchiffre le trafic complet (SSL/SSH) • Permet une analyse de contenu complète (antivirus, IPS...) • Plus sécurisé, mais plus lourd (latence et ressources)	Le pare-feu agit comme un “man-in-the-middle proxy SSL transparent”. 1. Le client initie une connexion HTTPS vers un site. 2. Le pare-feu intercepte le handshake TLS. 3. Il se fait passer pour le serveur auprès du client, avec un certificat intermédiaire généré par FortiGate. 4. Il établit ensuite une vraie connexion chiffrée avec le vrai serveur si son certificat est valide. 5. Il déchiffre le trafic au milieu, l'analyse (antivirus, IPS, filtrage...), puis le rechiffre vers le client. • Permet d'inspecter tout le contenu chiffré (HTTPS, SMTPS, IMAPS, etc.) • Active tous les moteurs de sécurité : - Antivirus - IPS - DLP (Data Loss Prevention) - Web Filtering - Contrôle applicatif • Bloque les malwares cachés dans le trafic SSL Inconvénients : • Consomme plus de CPU/RAM • Ajoute un peu de latence • Nécessite d'installer le certificat CA de FortiGate sur les postes clients pour éviter les alertes de sécurité • Peut poser problème avec certains services sensibles (banques, HSTS strict...) – possible de mettre ces sites à non-inspecté dans <i>Security Profiles > SSL/SSH Inspection > Exempt from SSL Inspection</i>



Les certificats numériques sont utilisés par le FortiGate pour :

- Inspection du trafic - FortiGate vérifie le certificat d'un serveur avant d'autoriser la connexion vers ce serveur.
- Confidentialité - Assurer la confidentialité des échanges avec d'autres dispositifs (accès à FortiGuarden HTTPS).
- Authentification
 - Authentification d'un utilisateur pour l'accès au réseau ou comme second facteur d'authentification. Vérification des champs *Subject* et *Subject Alternative Name*.
 - Authentification d'un appareil, par exemple, pour autoriser une connexion VPN.
 - Authentification de second facteur pour l'administrateur FortiGate

Invalid SSL certificates

FortiGate effectue les contrôles suivants sur les certificats :

- Contrôle de la date de validité.
- Contrôle de la signature du certificat.
- Contrôle de la liste de révocation (CRL)

Par défaut, les certificats invalides génèrent un avertissement dans le navigateur. Il est possible d'autoriser les certificats invalides.

- **Keep untrusted & Allow:** FortiGate autorise le site web et laisse le navigateur décider de l'action à entreprendre (signé par Fortinet_CA_Untrusted).
- **Block :** FortiGate bloque le contenu du site.
- **Trust & Allow:** Le FortiGate autorise le site web et considère le certificat comme fiable. (signé par Fortinet_CA_SSL)

Security Profiles > SSL/SSH Inspection

Common Options			
Invalid SSL certificates	Allow	Block	Custom
Expired certificates	Keep Untrusted & Allow	Block	Trust & Allow
Revoked certificates	Keep Untrusted & Allow	Block	Trust & Allow
Validation timed-out certificates	Keep Untrusted & Allow	Block	Trust & Allow
Validation failed certificates	Keep Untrusted & Allow	Block	Trust & Allow
Log SSL anomalies  			

Mécanismes de protection côté client

1. HSTS (HTTP Strict Transport Security)

- Force les navigateurs à utiliser uniquement HTTPS.
- Bloque tout accès si le certificat est invalide.
- Empêche les pare-feux d'intercepter ou rediriger vers HTTP.

2. Certificate Pinning

- Technique utilisée par certaines apps (ex. : Dropbox) pour refuser toute inspection SSL, même avec un certificat valide.
- L'application accepte uniquement un certificat spécifique codé en dur.

Conséquences sur l'inspection SSL/SSH :

- Toutes les applications SSL sont concernées (pas que les navigateurs) : FTPS, POP3S, SMTPS, LDAPS, Outlook 365, etc.
- Si FortiGate utilise le Full SSL inspection, des apps comme Dropbox peuvent cesser de fonctionner à cause du certificate pinning.

Solutions :

- Exclure les domaines sensibles de l'inspection SSL.
- Utiliser SSL Certificate Inspection (plus léger, pas de déchiffrement).

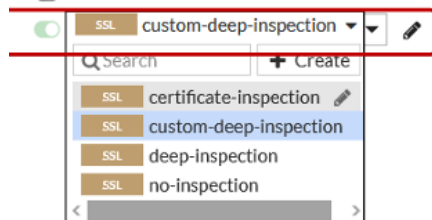


Figure 3 Choix de mode pour une règle de pare-feu

Filtrage WEB

Le **Web Filtering** permet de contrôler l'accès aux sites Web en fonction :

- de leur catégorie (ex. : jeux, réseaux sociaux, violence, finance...)
- de leur nom de domaine (FQDN) ou URL complète
- de listes personnalisées (allowlist/blocklist)

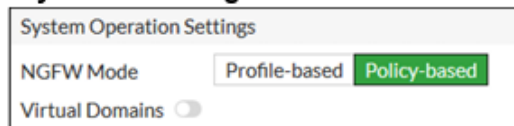
Quand ?

- Lors d'une requête HTTP(S), FortiGate intercepte la demande DNS, le handshake SSL et la requête HTTP.
- Si l'inspection SSL est activée (certificate ou full), il peut récupérer le FQDN (via SNI ou CN du certificat) pour catégoriser le site.



Deux types de Web Filtering :

System > settings



1. Profile-based

- On crée un profil Web Filter que l'on applique à une règle de pare-feu.
- Compatible avec les deux modes (flow et proxy).

2. Policy-based

- On définit directement le filtrage dans la règle de pare-feu.
- Uniquement disponible en mode flow-based.

- Nécessite Central NAT et SSL inspection configurée.

Fonctions de filtrage	Disponible en proxy	Disponible en flow
FortiGuard Categories Ex : heh.be – Education (definit par FortiGate)	✓ Oui	✓ Oui
Static URL Filter	✓ Oui	✓ Oui
Search engine filter (SafeSearch) (Google, Yahoo, Bing et Yandex) Un code est ajouté à l'URL pour imposer l'utilisation de safesearch Ex : pour Google, la chaîne "&safe=active" est ajoutée à l'URL	✓ Oui (deep SSL est requis)	✗ Non
Web content filter (par mots)	✓ Oui (deep SSL est requis)	✗ Non
Warning/Monitor/Authenticate actions	✓ Oui	✓ (profile-based uniquement)
Rating Options • On peut configurer accès complet aux sites si jamais FG n'arrive pas à inspecter • Activer Inspection URL ET IP	✓ Oui	✓ Oui
Quotas accès limité dans le temps ou dans le trafic (uniquement en mode proxy)	✓ Oui (+ Monitor/Warning/Authenticate)	✗ Non

Actions configurables :

- **Allow** : autoriser
- **Block** : bloquer
- **Monitor** : autoriser + journaliser
- **Warning** : avertir + possibilité d'accéder
- **Authenticate** : accès après authentification (les utilisateurs ne doivent pas s'authentifier à nouveau s'ils accèdent à d'autres sites Web de la même catégorie)

Proxy-based : ☒ Allow ☐ Monitor ☐ Block ☐ Warning ☐ Authenticate

Flow-based (Profile-based) : ☒ Allow ☐ Monitor ☐ Block ☐ Warning ☐ Authenticate

Flow-based (Policy-based) : Action définie dans la règle de pare-feu (accept/deny)

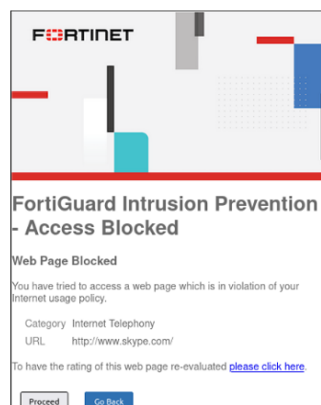


Figure 4. Block

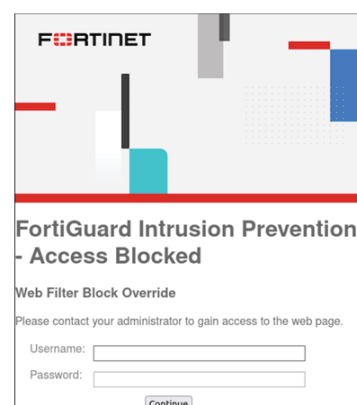


Figure 5. Authenticate

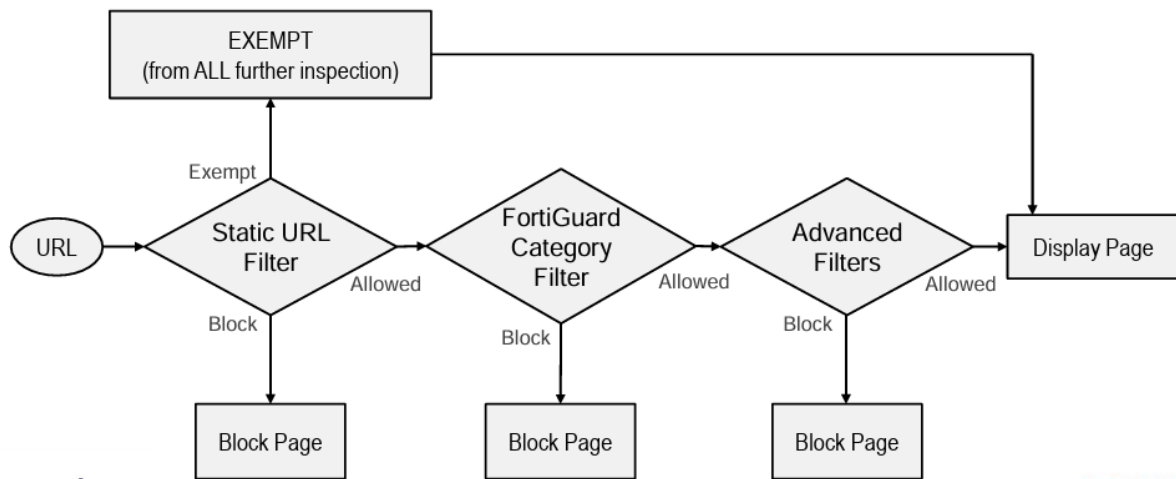


Figure 6. Filtre doit être autorisé dans toutes les étapes pour passer

DNS filtering

Avant une requête HTTP GET, les machines clientes utilisent des requêtes DNS pour connaître l'IP du serveur à joindre. Cette option filtre la requête DNS plutôt que la requête HTTP GET.

- Impacte tous les protocoles qui dépendent du DNS, pas seulement le trafic HTTP.
- Ne permet pas de filtrer aussi précisément que le filtrage HTTP.
- Prend en charge le filtrage d'URL et les catégories FortiGuard uniquement.
- Possible de filtrer les requêtes DNS chiffrées (> FortiOS7)

Etapes du filtrage DNS

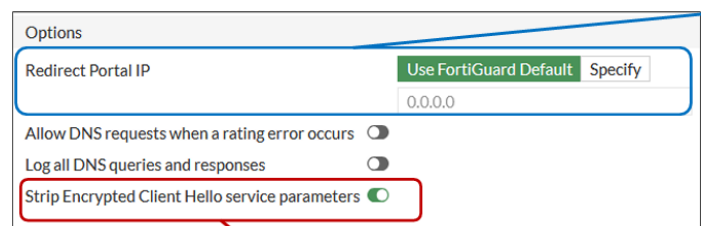
1. Lorsqu'il reçoit une requête DNS d'un client, FortiGate génère une requête DNS vers le service SDNS FortiGuard.
2. FortiGuard renvoie une adresse IP et une évaluation qui inclut la catégorie FortiGuard de la page Web demandée.
3. Le Fortigate effectue l'action configurée pour cette catégorie (Allow / Monitor / Block)

On peut activer DNS translation pour rediriger vers une IP configurée après la résolution précise.

L'option **"Strip Encrypted Client Hello service parameters"** sur FortiGate est une contre-mesure contre **ECH (Encrypted Client Hello)**, une extension TLS 1.3 destinée à masquer le nom du site web (SNI).

Comment ça marche ?

1. Un serveur compatible ECH (ex. : example.com) publie dans son enregistrement DNS (type HTTPS) une clé de chiffrement ECH.
2. Cette clé permet au client (navigateur) de chiffrer le SNI dans son message ClientHello.
3. Si FortiGate intercepte et retire cette clé dans la réponse DNS → le client ne peut pas chiffrer.
4. Résultat : FortiGate voit le SNI en clair → inspection et filtrage possibles



Filtrage Video

FortiGate Permet de contrôler l'accès au contenu YouTube (> FortiOS7) pour autoriser, surveiller ou bloquer :

- en fonction de la catégorie,

- Des chaînes YouTube spécifiques via leurs identifiants (Channel ID).

Prérequis :

- Nécessite d'activer l'inspection SSL/SSH complète.
- Nécessite une licence FortiGuard spécifique.
- Nécessite le mode d'inspection proxy.
- Nécessite une clé API YouTube

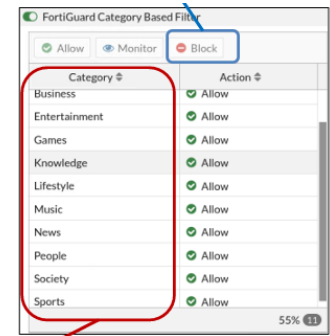


Figure 7. Exemples des catégories vidéo

Antivirus

Généralités

Empêche la propagation de menaces dans le réseau privé, Important de configurer sur Fortigate si pas possible de contrôler tous les périphériques (Wifi guest, BYOD...) ou bien si on ne peut pas installer d'antivirus sur ceux-ci pour d'autre raison.

Réputation de l'IP publique de l'entreprise, si des malwares y sortent c'est dangereux pour la société.

Analyse grayware : détection des programmes qui ont des effets secondaires **indésirables** (perte de productivité...) qui sont classé comme malveillant.

Analyse par signature : On détecte des bouts de codes, hash, ou combinaisons d'attributs etc qui font partie de bases de **données d'antivirus**. Une fois cette signature détectée elle est signalée comme virus. Ce Scan est très **rapide** et pas de faux positif. Mais ne peut bloquer que des **malwares connus**...Cependant il y a des polymorphes (qui changent de forme) pour échapper aux signatures.

Chaque jour, plateforme AV-TEST enregistre 350k nouveaux malwares et applications indésirables.

Les antivirus **Multi-scanner** ou multi-moteur utilisent plusieurs moteurs d'analyse antivirus simultanément.

AI-based malware detection (scan heuristique avant) utilise un modèle IA entraîné pour reconnaître les menaces collectées par FortiGuard Labs. Ça analyse le **comportements** et caractéristiques des fichiers. Détecte donc les structures **anormales**, lancement .exe dont le comportement n'est pas sécurisé, et autre. En triant les fichiers en **3** catégories : **Sain – Suspect – Malveillant**. Il y a des risques de faux positifs et ça consomme plus de ressources.

L'analyse du comportement se fait dans une **sandbox**, qui est un environnement virtuel sans risques. En cas de détections, il y a un **reporting** sur la menace. Il est possible d'utiliser une sandbox en cloud mais plus lent → **FortiGuard cloud** (SaaS) ou **FortiSandbox cloud** (PaaS). Limitations des sandbox c'est le nombre de **VM** simultanée et des techniques d'évasion de pirates.

Pour échapper à l'analyse il y a des moyens employés par les malwares (évasion) :

- ❖ Interaction humaine pour lancer le programme (clic)
- ❖ Détection d'une sandbox qui lance un mode de sommeil
- ❖ Fragmentation des données en plus petits bouts pour passer inaperçu.
- ❖ Chiffrement de l'objet malveillant.

Pour se protéger il faut une analyse en continu + avoir un plan si menace détectée trop tard.

Modes d'inspections

Flow-based inspection : Mode Flux, les paquets sont mis en cache et transmis immédiatement, ce qui consomme plus de ressources que le proxy-based. Supporte moins de fonctionnalités de sécurité mais les

paquets ne sont pas retardés (sauf le dernier) ! Le moteur antivirus scan le fichier en tampon, mais si le fichier est trop gros alors la taille supérieure à la mémoire tampon non scanné. Si le fichier est suspect alors connexion réinitialisée et non transmis.

Si besoin de performance alors flow-based !

Proxy-based inspection : Le fichier est bufferisé sur le FortiGate et aucune partie du fichier n'est transmise avant la fin du scan. Scan sur une taille maximum définie/taille maximale du tampon. Si plus gros alors configurable soit laisser passer soit bloquer. Pour rassurer l'utilisateur il est possible de faire envoyer des petits bouts du fichier quand même pour qu'il ne pense pas que rien ne se télécharge.

Si besoin de plus de sécurité alors proxy-based !

Autres configurations et informations

Possible de mapper certains ports spécifiques pour les scans.

Configuration de « RPC over http » qui permet un antivirus des courriels Microsoft Exchange Server qui utilisent RPC.

Avec un cache tampon de 10Mo seulement 0,01% des virus peuvent passer.

Les fichiers compressés sont scannés jusqu'à un certain nombre de compressions (12 par défaut), mais si compression avec mot de passe alors impossible à scanner.

Pour activer l'antivirus il faut l'appliquer sur les règles de Firewall souhaitées et activer le SSL deep inspection aussi.

Possible de tester antivirus avec des 'faux' virus comme 'eicar test file'.

Certains FortiGate peuvent avoir des puces d'accélération matérielle pour les tâches d'inspections, mais uniquement en flow-based.

Il est possible de mettre à jour la base de données des signatures de virus, mais uniquement avec une licence FortiGuard... Ainsi qu'activer la base de données étendue.

FortiGuard Protection Services permet une vérification des hash de fichier pour les virus non présent en base de données (licence supplémentaire ZHVO)